



P.I.L.

Public Information Limited, LLC.

SEC 397

Intermediate Cybersecurity Fundamentals

Version 1.0.0-v0.0.0

Table of Contents

- Course Overview 1
- Objectives 2
- Module 1: Foundations of Advanced Cybersecurity 3
 - Lesson 1.1: Threat Landscape Overview 3
 - Lesson 1.2: Security Frameworks and Standards 5
- Module 2: Network Security Fundamentals 6
 - Lesson 2.1: Network Architecture and Protocols 6
 - Lesson 2.2: Firewalls and Intrusion Detection Systems (IDS) 7
- Module 3: Cryptography Basics 9
 - Lesson 3.1: Symmetric and Asymmetric Encryption 9
 - Lesson 3.2: Digital Signatures and Certificates 11
- Module 4: Vulnerability and Risk Management 13
 - Lesson 4.1: Vulnerability Scanning Tools 13
 - Lesson 4.2: Introduction to Risk Management 15
- Module 5: Basic Incident Response 17
 - Lesson 5.1: Incident Response Lifecycle 17
 - Lesson 5.2: Reporting and Documentation 19

Course Overview

SEC 397 is an intermediate-level course tailored for professionals seeking to enhance their foundational cybersecurity knowledge before advancing to more sophisticated topics covered in SEC497. Through theoretical and hands-on modules, students will gain the skills necessary to understand core cybersecurity concepts, tools, and practices essential for defending against common threats.

Objectives

Upon completion, participants will be able to:

- Identify and mitigate common cyber threats.
- Understand core principles of network security and cryptography.
- Use industry-standard tools for vulnerability assessment and monitoring.
- Develop basic incident response and risk management plans.

Module 1: Foundations of Advanced Cybersecurity

Lesson 1.1: Threat Landscape Overview

Overview of Modern Cyber Threats and Tactics

The cybersecurity landscape is constantly evolving as new threats emerge and attackers refine their techniques. Understanding the current threat environment is critical for professionals tasked with safeguarding digital assets.

Key Threat Categories

- **Advanced Persistent Threats (APTs):** Prolonged, targeted attacks often sponsored by nation-states.
- **Zero-Day Exploits:** Exploitation of vulnerabilities not yet known to the vendor or the public.
- **Ransomware:** Malicious software that encrypts data and demands payment for decryption keys.
- **Phishing and Spear Phishing:** Deceptive emails or communications designed to trick users into providing sensitive information.
- **Supply Chain Attacks:** Exploiting vulnerabilities in third-party software or services.

Tactics and Techniques

- **Social Engineering:** Manipulating individuals to bypass security measures.
- **Distributed Denial of Service (DDoS):** Overwhelming a system with traffic to render it unusable.
- **Malware Delivery Mechanisms:** Examples include trojans, viruses, and worms.
- **Credential Stuffing:** Using stolen credentials from data breaches to gain unauthorized access.

Case Studies: High-Profile Breaches and Lessons Learned

1. Equifax Data Breach (2017):

- **Cause:** Unpatched vulnerability in Apache Struts.
- **Impact:** Personal data of 147 million people exposed.
- **Lesson:** Importance of timely patch management.

2. SolarWinds Supply Chain Attack (2020):

- **Cause:** Compromised software update mechanism.
- **Impact:** Breach of multiple U.S. government agencies and private companies.
- **Lesson:** Implementing robust monitoring and supply chain risk management.

3. Colonial Pipeline Ransomware Attack (2021):

- **Cause:** Compromised VPN credentials.
- **Impact:** Major fuel supply disruption in the U.S.
- **Lesson:** Strengthening multi-factor authentication and network segmentation.

Lesson 1.2: Security Frameworks and Standards

NIST Cybersecurity Framework (CSF)

The NIST Cybersecurity Framework provides a structured approach to managing and reducing cybersecurity risk. It consists of five core functions: 1. **Identify**: Understand organizational risks and prioritize them. 2. **Protect**: Implement safeguards to prevent security breaches. 3. **Detect**: Monitor and identify anomalies. 4. **Respond**: Develop processes for incident management. 5. **Recover**: Plan for resilience and restoration of systems.

ISO 27001: Information Security Management

ISO 27001 is an international standard for managing information security. Key elements include: - **Information Security Management System (ISMS)**: A systematic approach to securing sensitive information. - **Risk Assessment**: Identifying vulnerabilities and implementing controls. - **Continuous Improvement**: Regularly updating processes and policies.

CIS Controls

The CIS Controls are a prioritized set of best practices for cybersecurity defense: 1. **Inventory and Control of Enterprise Assets**: Maintain an accurate inventory of hardware and software. 2. **Secure Configuration**: Standardize and secure system configurations. 3. **Continuous Vulnerability Management**: Regularly update and patch systems. 4. **Access Control Management**: Limit and monitor user access to systems and data.

Module 2: Network Security Fundamentals

Lesson 2.1: Network Architecture and Protocols

Key Components of Secure Networks

A secure network architecture provides a strong foundation for protecting organizational data and systems. Critical components include:

- **Demilitarized Zone (DMZ):** A buffer zone that isolates public-facing services from internal systems.
- **Virtual Private Network (VPN):** Ensures encrypted communication over public networks.
- **Network Segmentation:** Dividing a network into smaller segments to limit lateral movement of threats.
- **Secure Access Points:** Ensuring physical and logical security of access points.
- **Redundant Systems:** High-availability designs to mitigate single points of failure.

TCP/IP and Common Network Vulnerabilities

The Transmission Control Protocol/Internet Protocol (TCP/IP) suite is the foundation of most networks. However, it introduces several vulnerabilities:

- **Man-in-the-Middle Attacks (MITM):** Interception of communications between two parties.
- **IP Spoofing:** Impersonating a trusted IP address.
- **Packet Sniffing:** Capturing unencrypted network traffic.
- **DNS Spoofing:** Redirecting users to malicious websites.
- **DDoS Attacks:** Flooding a network with excessive traffic.

Mitigation techniques include: - Using encryption protocols (e.g., TLS, HTTPS). - Implementing robust access controls. - Regularly monitoring network traffic for anomalies.

Lesson 2.2: Firewalls and Intrusion Detection Systems (IDS)

Introduction to Firewall Configuration

Firewalls serve as the first line of defense by filtering network traffic based on pre-defined rules. Key aspects of firewall configuration include:

- **Types of Firewalls:**
- **Packet-Filtering Firewalls:** Filter traffic based on IP, ports, and protocols.
- **Stateful Firewalls:** Monitor active sessions and allow traffic based on connection state.
- **Next-Generation Firewalls (NGFWs):** Include advanced features like application awareness and intrusion prevention.
- **Best Practices:**
- Regularly update firewall rules to reflect changing network needs.
- Block unused ports and protocols.
- Enable logging to track unauthorized access attempts.

Overview of IDS and IPS Systems

Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) are essential tools for monitoring and protecting networks from threats:

- **Intrusion Detection Systems (IDS):**
- **Signature-Based Detection:** Identifies threats by matching known attack patterns.
- **Anomaly-Based Detection:** Flags deviations from normal network behavior.
- **Limitation:** IDS are passive systems that alert but do not block attacks.
- **Intrusion Prevention Systems (IPS):**
- **Active Protection:** Detects and automatically blocks malicious traffic.
- **Deployment Modes:**
- **Inline Mode:** Directly processes and blocks traffic.
- **Promiscuous Mode:** Monitors traffic without blocking.
- **Best Practices:**

- Update signature databases regularly.
- Fine-tune detection rules to minimize false positives.

Implementing firewalls, IDS, and IPS in combination creates a layered defense strategy that reduces the risk of network breaches.

Module 3: Cryptography Basics

Lesson 3.1: Symmetric and Asymmetric Encryption

Fundamentals of Encryption Techniques

Encryption is the process of converting plain text into unreadable ciphertext to protect data. It relies on algorithms and keys to secure communication.

- **Symmetric Encryption:**
 - Uses the same key for encryption and decryption.
 - Faster and suitable for encrypting large datasets.
 - Examples: AES (Advanced Encryption Standard), DES (Data Encryption Standard).
 - Limitation: Requires secure key exchange between parties.
- **Asymmetric Encryption:**
 - Uses a key pair: a public key for encryption and a private key for decryption.
 - Eliminates the need for secure key exchange.
 - Examples: RSA, ECC (Elliptic Curve Cryptography).
 - Limitation: Slower than symmetric encryption, making it less suitable for large data.

Use Cases of Symmetric vs. Asymmetric Encryption

- **Symmetric Encryption:**
 - File storage encryption (e.g., BitLocker, VeraCrypt).
 - Securing database records.
 - Bulk data transfer over secure channels.
- **Asymmetric Encryption:**
 - Secure email communication (e.g., PGP).
 - Establishing secure connections (e.g., SSL/TLS handshake).
 - Digital signatures for verifying data authenticity.

Lesson 3.2: Digital Signatures and Certificates

Importance of Digital Certificates in Securing Communications

Digital certificates are essential for verifying the identity of entities and enabling secure communication.

- **Digital Signatures:**
 - Ensure message authenticity and integrity.
 - Generated using a sender's private key and verified with their public key.
 - Common standards: DSA (Digital Signature Algorithm), RSA.
- **Digital Certificates:**
 - Issued by Certificate Authorities (CAs) to bind public keys to entities.
 - Components include entity information, public key, expiration date, and CA signature.
 - Common protocols: X.509 standard.

Lab: Implementing SSL/TLS Certificates

This hands-on lab guides students through the process of implementing SSL/TLS certificates for secure communication.

1. **Objective:** Secure a web server using an SSL/TLS certificate.
2. **Steps:**
 - Generate a private key and a Certificate Signing Request (CSR).
 - Submit the CSR to a Certificate Authority (CA).
 - Install the issued certificate on the web server.
 - Configure the server to enforce HTTPS connections.
3. **Tools:** OpenSSL, Apache/Nginx web server.
4. **Expected Outcome:**
 - Understand how SSL/TLS certificates work.
 - Successfully configure a secure web server.

Module 4: Vulnerability and Risk Management

Lesson 4.1: Vulnerability Scanning Tools

Overview of Tools like Nessus and OpenVAS

Vulnerability scanning tools play a vital role in identifying and addressing security gaps in an organization's systems and networks.

- **Nessus:**
 - Developed by Tenable.
 - Capabilities:
 - Identifying misconfigurations, missing patches, and insecure protocols.
 - Predefined templates for regulatory compliance (e.g., PCI-DSS).
 - Detailed reporting features for prioritizing remediation.
 - Best for: Enterprise-scale vulnerability assessments.
- **OpenVAS (Open Vulnerability Assessment System):**
 - An open-source alternative managed by Greenbone Networks.
 - Capabilities:
 - Regular vulnerability database updates.
 - Scans for misconfigurations, outdated software, and weak credentials.
 - Best for: Cost-conscious organizations or smaller setups.

Hands-On: Performing a Basic Scan

Objective: Learn to configure and execute a basic vulnerability scan using either Nessus or OpenVAS.

1. Setup:

- Choose a tool (e.g., Nessus free trial or OpenVAS).
- Install the tool in a lab environment (e.g., virtual machines or isolated test networks).

2. Steps:

◦ Configuration:

- Define a scan target (e.g., a virtual machine with known vulnerabilities).
- Select a scan template (e.g., Basic Network Scan for Nessus).

◦ Execution:

- Launch the scan and monitor its progress.

◦ Analysis:

- Review scan results for vulnerabilities.
- Categorize findings by severity (Critical, High, Medium, Low).

3. Deliverables:

- Generate and save a scan report.
- Discuss remediation strategies based on scan results.

4. Expected Outcome:

- Ability to set up and run a vulnerability scan.
- Understand and interpret scan results to prioritize actions.

Lesson 4.2: Introduction to Risk Management

Concepts of Risk Assessment and Mitigation

Risk management is the cornerstone of effective cybersecurity. It ensures organizations can identify, evaluate, and address potential threats.

- **Risk Assessment:**
 - Identify assets (e.g., data, systems) and their associated vulnerabilities.
 - Evaluate threats based on:
 - **Likelihood:** Probability of the risk occurring.
 - **Impact:** Potential damage if the risk materializes.
- **Risk Mitigation Strategies:**
 - **Preventive Controls:** Firewalls, antivirus software, and access controls.
 - **Detective Controls:** Monitoring tools, IDS/IPS.
 - **Corrective Controls:** Backup systems, incident response plans.
 - **Residual Risk:** The remaining risk after mitigation measures are in place. Organizations must decide if this level of risk is acceptable.

Developing Simple Risk Management Plans

Objective: Create a practical risk management plan for a fictional organization.

1. Steps:

- **Asset Identification:**
- List critical assets (e.g., customer data, intellectual property).
- **Threat Analysis:**
- Identify potential risks (e.g., insider threats, ransomware).
- **Risk Evaluation:**
- Assign risk levels using a risk matrix (Low, Medium, High).
- **Mitigation Planning:**
- Propose controls for high-priority risks (e.g., regular software updates, training programs).
- **Documentation:**
- Create a Risk Register summarizing the assessment and mitigation actions.

2. Deliverables:

- **Risk Register:** A log of identified risks, mitigation measures, and risk levels.
- **Policy Document:** High-level guidelines for ongoing risk assessment and mitigation.

3. Expected Outcome:

- Gain hands-on experience in developing risk management plans.
- Understand how to align risk management with organizational objectives.

Module 5: Basic Incident Response

Lesson 5.1: Incident Response Lifecycle

Overview of NIST Incident Response Framework

The NIST Incident Response Framework provides a structured approach to handling security incidents effectively. It consists of the following key phases:

- **Preparation:**
 - Establish an incident response plan.
 - Train employees and set up necessary tools (e.g., monitoring systems, forensic tools).
 - Conduct regular drills and simulations.
- **Detection and Analysis:**
 - Identify potential security events through monitoring systems.
 - Validate incidents by analyzing logs, alerts, and reports.
 - Categorize incidents based on severity and impact.
- **Containment, Eradication, and Recovery:**
 - **Containment:** Limit the spread of the threat (e.g., isolate affected systems).
 - **Eradication:** Remove the root cause (e.g., delete malware, patch vulnerabilities).
 - **Recovery:** Restore normal operations and monitor for residual threats.
- **Post-Incident Activities:**
 - Conduct a lessons-learned session.
 - Update response plans based on insights gained.
 - Enhance detection and prevention measures.

Role-Playing Exercise: Responding to a Simulated Breach

Objective: Apply the Incident Response Lifecycle in a simulated environment.

1. **Scenario:** A simulated ransomware attack targeting a fictional organization.
2. **Teams:**
 - **Incident Response Team:** Handles detection, containment, and recovery.
 - **Management Team:** Makes critical decisions (e.g., communications, resource allocation).
3. **Steps:**
 - Identify the breach and determine its impact.
 - Implement containment measures (e.g., disconnecting infected systems).
 - Develop an eradication and recovery strategy.
 - Document actions and create a post-incident report.
4. **Expected Outcome:**
 - Hands-on experience managing an incident.
 - Understanding the importance of communication and documentation during a breach.

Lesson 5.2: Reporting and Documentation

Importance of Maintaining Incident Logs

Incident logs serve as the foundation for effective incident management and compliance. Key benefits include:

- **Record Keeping:** Provides a timeline of events and actions taken.
- **Compliance:** Demonstrates adherence to regulatory requirements.
- **Post-Incident Analysis:** Identifies gaps in response and areas for improvement.

What to Include in an Incident Log: - Date and time of detection. - Description of the incident. - Actions taken (e.g., containment, mitigation). - Names of involved personnel. - Resolution steps and outcomes.

Templates for Basic Incident Reporting

Structured incident reports ensure consistency and completeness in documentation.

1. Basic Incident Report Template:

- **Incident ID:** Unique identifier for tracking.
- **Date/Time:** When the incident occurred and was detected.
- **Description:** Summary of the event.
- **Impact:** Affected systems, data, and business operations.
- **Root Cause:** Explanation of how the incident occurred.
- **Actions Taken:** Steps for containment, eradication, and recovery.
- **Recommendations:** Preventative measures for the future.

2. Post-Incident Review Template:

- **Timeline of Events:** Key milestones and actions.
- **Effectiveness of Response:** Evaluation of team performance.
- **Lessons Learned:** Insights for improving future responses.
- **Plan Updates:** Revisions to the Incident Response Plan.

3. Lab Activity:

- Practice filling out an incident report based on the breach simulation from Lesson 5.1.
- Review and critique reports with peers to identify strengths and weaknesses.